

SOFTWARE REQUIREMENTS SPECIFICATION (SRS)

System Name: Course Management System (BE IOC Java Web Services)

Standard: IEEE Std 830-1998 / ISO/IEC/IEEE 29148:2018

1. INTRODUCTION

1.1 Purpose

Tài liệu Đặc tả Yêu cầu Phần mềm (SRS) này mô tả chi tiết, toàn diện các yêu cầu chức năng, phi chức năng, mô hình cơ sở dữ liệu và danh mục RESTful API cho **Hệ thống Quản lý Khóa học (Course Management System - CMS)** thuộc dự án **TSUBASA PLUS Java Web Services**. Tài liệu được chuẩn hóa theo tiêu chuẩn quốc tế **IEEE Std 830-1998** và **ISO/IEC/IEEE 29148:2018**, đóng vai trò là tài liệu chuẩn cho kiến trúc sư phần mềm, lập trình viên Backend/Frontend, đội ngũ QA/Kiểm thử và Giảng viên đánh giá.

1.2 Scope

Hệ thống Quản lý Khóa học là dịch vụ Web Backend theo kiến trúc RESTful API xây dựng trên nền tảng Java Web Services (Spring Boot). Hệ thống quản lý toàn bộ vòng đời của hoạt động đào tạo trực tuyến, bao gồm:

- **Identity & Access Management (IAM):** Quản lý tài khoản và phân quyền dựa trên vai trò (RBAC) với 6 ngữ cảnh truy cập (**PUBLIC, AUTH, STUDENT, TEACHER, ADMIN, OWNER_OR_ADMIN**) sử dụng cơ chế xác thực vô trạng thái JSON Web Token (JWT).
- **Quản lý Khóa học & Nội dung Bài học:** Quản lý chuyển trạng thái vòng đời khóa học (**DRAFT, PUBLISHED, ARCHIVED**) và các bài học cấu trúc phân cấp.
- **Đăng ký Học & Theo dõi Tiến độ:** Đăng ký khóa học tự động, kiểm soát trùng lặp và tính toán tiến độ hoàn thành dựa trên danh sách bài học đã học (**LessonProgress**).
- **Tương tác & Đánh giá:** Hệ thống thông báo sự kiện tự động và tiếp nhận đánh giá/bình luận (1-5 sao) từ sinh viên.

- **Báo cáo & Thống kê Analytics:** Cung cấp các Endpoint báo cáo phục vụ quản trị viên theo dõi độ phổ biến khóa học, tiến độ học viên và hiệu suất giảng viên

1.3 Definitions, Acronyms, and Abbreviations

Thuật ngữ / Từ viết tắt	Định nghĩa
SRS	Software Requirements Specification — Tài liệu đặc tả yêu cầu phần mềm chuẩn.
IEEE Std 830	Tiêu chuẩn khuyến nghị của IEEE về xây dựng tài liệu SRS.
RBAC	Role-Based Access Control — Mô hình kiểm soát truy cập dựa trên vai trò.
JWT	JSON Web Token — Chuẩn mã hóa token xác thực người dùng không lưu trạng thái (Stateless).
CRUD	Create, Read, Update, Delete — 4 thao tác dữ liệu cơ bản.
3NF	Third Normal Form — Dạng chuẩn 3 trong thiết kế cơ sở dữ liệu quan hệ.

2. OVERALL DESCRIPTION

2.1 Product Perspective

Hệ thống Quản lý Khóa học đóng vai trò là dịch vụ Backend độc lập, giao tiếp với các ứng dụng Frontend (Web/Mobile) thông qua chuẩn RESTful HTTP/HTTPS API và tương tác với Cơ sở dữ liệu quan hệ (MySQL / PostgreSQL).

2.2 User Classes and Characteristics (RBAC)

- **PUBLIC:** Người dùng vắng lai chưa xác thực, chỉ thực hiện chức năng đăng nhập.

- **AUTH:** Người dùng đã xác thực (mọi role), có quyền xem hồ sơ cá nhân, tìm kiếm, duyệt bài học/khóa học đã xuất bản.
- **STUDENT:** Sinh viên đăng ký khóa học, học bài học, đánh dấu tiến độ hoàn thành và gửi đánh giá.
- **TEACHER:** Giảng viên phụ trách, có quyền quản lý, tạo, chỉnh sửa và xuất bản các bài học thuộc khóa học do mình phụ trách.
- **ADMIN:** Quản trị viên toàn quyền hệ thống (quản lý người dùng, đổi quyền, kích hoạt tài khoản, tạo khóa học, xem báo cáo).
- **OWNER_OR_ADMIN:** Chính chủ tài nguyên (hoặc Admin) mới có quyền cập nhật/xóa thông tin hoặc bình luận.

3. SYSTEM FEATURES & RESTFUL API SPECIFICATIONS

Toàn bộ **44 API Endpoints** được phân loại chi tiết theo từng phân hệ chức năng cùng thông số phân bổ điểm đánh giá:

3.1 Phân hệ 1: Authentications & Users Management

STT	API Endpoint	Method	Role	Mô tả chức năng	Loại yêu cầu
1	/api/auth/login	POST	PUBLIC	Đăng nhập và nhận token xác thực (JWT)	Bắt buộc
2	/api/auth/verify	POST	AUTH	Xác thực token người dùng	Bắt buộc
3	/api/auth/me	GET	AUTH	Lấy thông tin hồ sơ của người dùng hiện tại	Bắt buộc
4	/api/users	GET	ADMIN	Lấy danh sách tất cả người dùng (lọc role, status)	Bắt buộc
5	/api/users/{user_id}	GET	ADMIN	Lấy thông tin chi tiết một người dùng	Bắt buộc

6	/api/users	POST	ADMIN	Tạo tài khoản người dùng mới	Bắt buộc
7	/api/users/{user_id}/role	PUT	ADMIN	Cập nhật vai trò (ADMIN không được sửa ROLE của ADMIN khác)	Bắt buộc
8	/api/users/{user_id}/status	PUT	ADMIN	Kích hoạt/vô hiệu hóa tài khoản (is_active)	Bắt buộc
9	/api/users/{user_id}	DELETE	ADMIN	Xóa người dùng khỏi hệ thống	Bắt buộc
26	/api/users/{user_id}	PUT	OWNER_ OR_ADMIN	Cập nhật thông tin cá nhân người dùng	Bắt buộc
27	/api/users/{user_id}/password	PUT	OWNER_ OR_ADMIN	Đổi mật khẩu người dùng	Bắt buộc

30	/api/auth/logout	POST	AUTH	Đăng xuất (invalidate token)	Mở rộng
31	/api/users?status={status}	GET	ADMIN	Lọc người dùng theo trạng thái (active/inactive)	Mở rộng

3.2 Phân hệ 2: Courses Management

STT	API Endpoint	Method	Role	Mô tả chức năng	Loại yêu cầu
10	/api/courses	GET	AUTH	Lấy danh sách tất cả khóa học (Lọc PUBLISHED)	Bắt buộc
11	/api/courses/{course_id}	GET	AUTH	Chi tiết khóa học (bao gồm bài học PUBLISHED)	Bắt buộc
12	/api/courses	POST	ADMIN	Tạo khóa học mới (gán giảng viên, trạng thái ban đầu DRAFT)	Bắt buộc
13	/api/courses/{course_id}	PUT	ADMIN	Cập nhật thông tin chi tiết khóa học	Bắt buộc

14	/api/courses/{course_id}/status	PUT	ADMIN	Đổi trạng thái (DRAFT, PUBLISHED, ARCHIVED)	Bắt buộc
15	/api/courses/{course_id}	DELETE	ADMIN	Xóa khóa học	Bắt buộc
28	/api/courses?search={keyword}	GET	AUTH	Tìm kiếm khóa học theo từ khóa trong tiêu đề/mô tả	Bắt buộc
29	/api/courses?teacher_id={teacher_id}	GET	AUTH	Lọc khóa học theo giảng viên phụ trách	Bắt buộc
32	/api/courses?status={status}	GET	AUTH	Lọc khóa học theo trạng thái	Mở rộng

3.3 Phân hệ 3: Lessons Management

STT	API Endpoint	Method	Role	Mô tả chức năng	Loại yêu cầu
16	/api/courses/{course_id}/lessons	GET	AUTH	Danh sách bài học trong khóa học (chỉ hiển thị PUBLISHED)	Bắt buộc
17	/api/lessons/{lesson_id}	GET	AUTH	Lấy thông tin chi tiết một bài học (PUBLISHED)	Bắt buộc
18	/api/courses/{course_id}/lessons	POST	TEACHER_OR_ADMIN	Thêm bài học mới (TEACHER phải phụ trách khóa học)	Bắt buộc
19	/api/lessons/{lesson_id}	PUT	TEACHER_OR_ADMIN	Cập nhật thông tin bài học	Bắt buộc

20	/api/lessons/{lesson_id}/publish	PUT	TEACHER_OR_ADMIN	Cập nhật trạng thái hiển thị (is_published)	Bắt buộc
21	/api/lessons/{lesson_id}	DELETE	TEACHER_OR_ADMIN	Xóa bài học khỏi khóa học	Bắt buộc
44	/api/lessons/{lesson_id}/content_preview	GET	AUTH	Lấy nội dung xem trước của bài học	Mở rộng

3.4 Phân hệ 4: Enrollments & Progress Tracking

STT	API Endpoint	Method	Role	Mô tả chức năng	Loại yêu cầu
22	/api/enrollments	GET	STUDENT	Danh sách các khóa học sinh viên đã đăng ký	Bắt buộc
23	/api/enrollments	POST	STUDENT	Đăng ký một khóa học mới	Bắt buộc

24	/api/enrollments/{enrollment_id}	GET	STUDENT	Lấy chi tiết thông tin đăng ký & tiến độ học tập	Bắt buộc
25	/api/enrollments/{enrollment_id}/complete_lesson/{lesson_id}	PUT	STUDENT	Cập nhật tiến độ: Đánh dấu bài học hoàn thành	Bắt buộc

3.5 Phân hệ 5 & 6: Notifications, Reviews & Analytics

STT	API Endpoint	Method	Role	Mô tả chức năng	Loại yêu cầu
33	/api/notifications	GET	AUTH	Lấy danh sách thông báo của người dùng	Mở rộng
34	/api/notifications/{notification_id}/read	PUT	AUTH	Đánh dấu thông báo đã đọc	Mở rộng
35	/api/notifications	POST	ADMIN	Tạo thông báo mới cho người dùng	Mở rộng
36	/api/notifications/{notification_id}	DELETE	ADMIN	Xóa thông báo	Mở rộng

37	/api/reports/top_courses	GET	ADMIN	Thống kê khóa học phổ biến nhất theo lượt đăng ký	Mở rộng
38	/api/reports/student_progress/{student_id}	GET	ADMIN	Thống kê tiến độ học của sinh viên cụ thể	Mở rộng
39	/api/reports/teacher_courses_overview/{teacher_id}	GET	ADMIN	Thống kê tổng quan các khóa học của giảng viên	Mở rộng

40	/api/courses/{course_id}/reviews	GET	AUTH	Lấy danh sách đánh giá/bình luận về khóa học	Mở rộng
41	/api/courses/{course_id}/reviews	POST	STUDENT	Sinh viên gửi đánh giá/bình luận khóa học đã học	Mở rộng
42	/api/reviews/{review_id}	PUT	OWNER_OR_ADMIN	Cập nhật đánh giá/bình luận	Mở rộng
43	/api/reviews/{review_id}	DELETE	OWNER_OR_ADMIN	Xóa đánh giá/bình luận	Mở rộng

4. DATABASE SYSTEM SPECIFICATION & ENTITY DESCRIPTION

Hệ thống cơ sở dữ liệu quan hệ được thiết kế đạt chuẩn **Dạng chuẩn 3 (3NF)**, đảm bảo tối ưu hóa lưu trữ, tránh dư thừa dữ liệu và duy trì tính toàn vẹn tham chiếu nghiêm ngặt. Dưới đây là mô tả chi tiết 7 thực thể cấu thành hệ thống:

4.1 Thực thể Users (Người dùng)

- **Mục đích:** Lưu trữ thông tin tài khoản và quản lý phân quyền (RBAC) của toàn bộ cá nhân tham gia hệ thống (Admin, Giảng viên, Sinh viên).
- **Mô tả thuộc tính:**
 - **user_id:** Định danh duy nhất cho từng người dùng (Khóa chính, Số nguyên tự tăng).
 - **username:** Tên tài khoản dùng để đăng nhập (Chuỗi ký tự, Duy nhất, Không được để trống).
 - **password_hash:** Chuỗi mật khẩu đã qua mã hóa an toàn bằng thuật toán BCrypt (Chuỗi ký tự, Không được để trống).
 - **email:** Địa chỉ email liên lạc của người dùng (Chuỗi ký tự, Duy nhất, Không được để trống).
 - **full_name:** Họ và tên đầy đủ của người dùng (Chuỗi ký tự, Không được để trống).
 - **role:** Vai trò phân quyền trong hệ thống; chấp nhận một trong các giá trị ADMIN, TEACHER, hoặc STUDENT (Kiểu liệt kê ENUM, Mặc định là STUDENT, Không được để trống).
 - **is_active:** Trạng thái cho phép tài khoản hoạt động hoặc bị khóa (Kiểu Luận lý Boolean, Mặc định TRUE, Không được để trống).
 - **created_at:** Dấu thời gian ghi nhận thời điểm tạo tài khoản (Kiểu Ngày giờ Datetime, Mặc định thời gian hiện tại).
 - **updated_at:** Dấu thời gian ghi nhận lần cập nhật tài khoản gần nhất (Kiểu Ngày giờ Datetime, Tự động cập nhật khi có thay đổi).

4.2 Thực thể Courses (Khóa học)

- **Mục đích:** Lưu trữ thông tin tổng quan về các khóa học được tổ chức trên hệ thống và liên kết phụ trách với Giảng viên.
- **Mô tả thuộc tính:**
 - **course_id:** Định danh duy nhất cho mỗi khóa học (Khóa chính, Số nguyên tự tăng).
 - **title:** Tiêu đề hiển thị của khóa học (Chuỗi ký tự, Không được để trống).
 - **description:** Mô tả chi tiết về nội dung, mục tiêu và yêu cầu của khóa học (Văn bản dài TEXT, Có thể để trống).
 - **teacher_id:** Định danh giảng viên phụ trách chính khóa học (Khóa ngoại tham chiếu đến Users.user_id, Yêu cầu role = 'TEACHER', Không được để trống).

- **price**: Giá bán của khóa học tính bằng đơn vị tiền tệ (Số thập phân, Mặc định 0.00).
- **duration_hours**: Tổng thời lượng ước tính của khóa học tính theo giờ (Số nguyên, Có thể để trống).
- **status**: Trạng thái vòng đời của khóa học; chấp nhận các giá trị DRAFT (Bản nháp), PUBLISHED (Đã xuất bản/Đang mở), hoặc ARCHIVED (Đã lưu trữ/Đóng) (Kiểu liệt kê ENUM, Mặc định DRAFT, Không được để trống).
- **created_at**: Thời điểm khởi tạo khóa học (Kiểu Ngày giờ Datetime).
- **updated_at**: Thời điểm cập nhật thông tin khóa học lần cuối (Kiểu Ngày giờ Datetime).

4.3 Thực thể Lessons (Bài học)

- **Mục đích**: Quản lý danh mục bài học, nội dung giảng dạy và thứ tự phân bổ bài học bên trong một khóa học cụ thể.
- **Mô tả thuộc tính**:
 - **lesson_id**: Định danh duy nhất cho từng bài học (Khóa chính, Số nguyên tự tăng).
 - **course_id**: Định danh khóa học chứa bài học này (Khóa ngoại tham chiếu đến Courses.course_id, Không được để trống).
 - **title**: Tiêu đề hoặc tên bài học (Chuỗi ký tự, Không được để trống).
 - **content_url**: Đường dẫn URL tài liệu đính kèm, video bài giảng hoặc slide trình chiếu (Chuỗi ký tự, Có thể để trống).
 - **text_content**: Nội dung bài học dạng văn bản chi tiết hoặc hướng dẫn làm bài (Văn bản dài TEXT, Có thể để trống).
 - **order_index**: Thứ tự sắp xếp hiển thị của bài học trong chuỗi danh sách bài học của khóa học (Số nguyên, Không được để trống).
 - **is_published**: Trạng thái cho phép bài học hiển thị tới sinh viên (Kiểu Luận lý Boolean, Mặc định FALSE, Không được để trống).
 - **created_at**: Thời điểm bài học được tạo (Kiểu Ngày giờ Datetime).
 - **updated_at**: Thời điểm sửa đổi bài học lần cuối (Kiểu Ngày giờ Datetime).

4.4 Thực thể Enrollments (Đăng ký khóa học)

- **Mục đích**: Ghi nhận thông tin đăng ký học của Sinh viên đối với Khóa học và theo dõi tổng quan tiến độ hoàn thành khóa học đó.
- **Mô tả thuộc tính**:
 - **enrollment_id**: Định danh duy nhất cho bản ghi đăng ký (Khóa chính, Số nguyên tự tăng).
 - **student_id**: Định danh sinh viên thực hiện đăng ký (Khóa ngoại tham chiếu đến Users.user_id, Yêu cầu role = 'STUDENT', Không được để trống).
 - **course_id**: Định danh khóa học được sinh viên đăng ký (Khóa ngoại tham chiếu đến Courses.course_id, Không được để trống).
 - **enrollment_date**: Ngày giờ sinh viên đăng ký thành công khóa học (Kiểu Ngày giờ Datetime, Mặc định thời gian hiện tại).

- **status**: Trạng thái tham gia khóa học; chấp nhận các giá trị ENROLLED (Đang học), COMPLETED (Đã hoàn thành), hoặc DROPPED (Hủy/Bỏ học) (Kiểu liệt kê ENUM, Mặc định ENROLLED, Không được để trống).
- **completion_date**: Ngày giờ sinh viên hoàn thành tất cả các bài học trong khóa (Kiểu Ngày giờ Datetime, Có thể để trống).
- **progress_percentage**: Tỷ lệ phần trăm tiến độ hoàn thành khóa học dựa trên tổng số bài học đã học (Số thập phân, Ràng buộc giá trị nằm trong khoảng từ 0.00 đến 100.00, Mặc định 0.00).
- **Ràng buộc toàn vẹn đặc biệt:**
 - UNIQUE(student_id, course_id): Đảm bảo mỗi sinh viên chỉ có thể tạo duy nhất một bản ghi đăng ký đối với mỗi khóa học.

4.5 Thực thể LessonProgress (Tiến độ bài học)

- **Mục đích**: Theo dõi chi tiết việc truy cập và hoàn thành từng bài học cụ thể của sinh viên trong lượt đăng ký tương ứng.
- **Mô tả thuộc tính**:
 - **progress_id**: Định danh duy nhất cho bản ghi tiến độ (Khóa chính, Số nguyên tự tăng).
 - **enrollment_id**: Định danh lượt đăng ký tương ứng của sinh viên (Khóa ngoại tham chiếu đến Enrollments.enrollment_id, Không được để trống).
 - **lesson_id**: Định danh bài học đang được theo dõi tiến độ (Khóa ngoại tham chiếu đến Lessons.lesson_id, Không được để trống).
 - **is_completed**: Đánh dấu sinh viên đã hoàn thành bài học này hay chưa (Kiểu Luận lý Boolean, Mặc định FALSE, Không được để trống).
 - **completed_at**: Thời điểm sinh viên đánh dấu hoàn thành bài học (Kiểu Ngày giờ Datetime, Có thể để trống).
 - **last_accessed_at**: Thời điểm gần nhất sinh viên truy cập vào bài học này (Kiểu Ngày giờ Datetime, Tự động cập nhật).
- **Ràng buộc toàn vẹn đặc biệt**:
 - UNIQUE(enrollment_id, lesson_id): Đảm bảo mỗi bài học trong một lượt đăng ký học chỉ tồn tại duy nhất một bản ghi theo dõi tiến độ.

4.6 Thực thể Notifications (Thông báo)

- **Mục đích**: Lưu trữ các thông điệp, sự kiện hệ thống tạo tự động hoặc do Quản trị viên gửi tới người dùng cụ thể.
- **Mô tả thuộc tính**:
 - **notification_id**: Định danh duy nhất cho mỗi thông báo (Khóa chính, Số nguyên tự tăng).
 - **user_id**: Định danh người dùng nhận thông báo (Khóa ngoại tham chiếu đến Users.user_id, Không được để trống).
 - **message**: Nội dung chi tiết của thông báo (Văn bản dài TEXT, Không được để trống).

- **type**: Phân loại nguồn sự kiện tạo thông báo như NEW_COURSE, LESSON_UPDATED, ENROLLMENT_CONFIRMED (Chuỗi ký tự, Có thể để trống).
- **target_url**: Đường dẫn điều hướng liên quan khi người dùng nhấp vào thông báo (Chuỗi ký tự, Có thể để trống).
- **is_read**: Đánh dấu trạng thái người dùng đã đọc thông báo hay chưa (Kiểu Luận lý Boolean, Mặc định FALSE, Không được để trống).
- **created_at**: Thời điểm thông báo được khởi tạo và phát đi (Kiểu Ngày giờ Datetime).

4.7 Thực thể Reviews (Đánh giá khóa học)

- **Mục đích**: Lưu trữ phản hồi, xếp hạng sao và bình luận của sinh viên sau khi tham gia khóa học.
- **Mô tả thuộc tính**:
 - **review_id**: Định danh duy nhất cho đánh giá (Khóa chính, Số nguyên tự tăng).
 - **course_id**: Định danh khóa học nhận đánh giá (Khóa ngoại tham chiếu đến Courses.course_id, Không được để trống).
 - **student_id**: Định danh sinh viên viết đánh giá (Khóa ngoại tham chiếu đến Users.user_id, Không được để trống).
 - **rating**: Điểm đánh giá xếp hạng sao cho khóa học (Số nguyên, Ràng buộc giá trị nghiêm ngặt từ 1 đến 5 sao, Không được để trống).
 - **comment**: Lời bình luận hoặc nhận xét chi tiết của sinh viên về nội dung/giảng viên (Văn bản dài TEXT, Có thể để trống).
 - **created_at**: Thời điểm viết đánh giá (Kiểu Ngày giờ Datetime).
 - **updated_at**: Thời điểm chỉnh sửa đánh giá gần nhất (Kiểu Ngày giờ Datetime).
- **Ràng buộc toàn vẹn đặc biệt**:
 - UNIQUE(course_id, student_id): Đảm bảo mỗi sinh viên chỉ được phép viết duy nhất một bản ghi đánh giá cho một khóa học.

5. NON-FUNCTIONAL REQUIREMENTS

- **Bảo mật (Security)**:
 - Mã hóa toàn bộ mật khẩu người dùng bằng thuật toán BCrypt trước khi lưu trữ.
 - Truy cập các Endpoint bảo vệ bắt buộc có Token xác thực JWT trong Header: Authorization: Bearer <token>.
 - Phân quyền RBAC nghiêm ngặt: Admin không được quyền sửa Role của Admin khác; Giảng viên chỉ được quản lý các bài học thuộc khóa học do mình phụ trách.
- **Hiệu năng (Performance)**:
 - Thời gian phản hồi API (Response time) dưới **200ms** cho các tác vụ CRUD thông thường.

- Tối ưu truy vấn SQL, đánh Index cho các khóa ngoại và trường thường xuyên lọc (user_id, course_id, status).
- **Ràng buộc Toàn vẹn Dữ liệu (Data Integrity):**
 - Tự động tính lại Enrollments.progress_percentage theo công thức: (Số bài học hoàn thành / Tổng số bài học PUBLISHED) * 100.
 - Đảm bảo mỗi sinh viên chỉ được đăng ký 1 khóa học 1 lần và gửi tối đa 1 đánh giá cho mỗi khóa học (UNIQUE CONSTRAINT)

6. EXCEPTION HANDLING & API RESPONSE STANDARDIZATION

Để đảm bảo tính nhất quán, mượt mà khi tích hợp giữa các ứng dụng Client (ReactJS, Mobile App, Postman) và Web Service Backend (Spring Boot), toàn bộ dữ liệu phản hồi (Response) và quy trình xử lý ngoại lệ (Exception Handling) trong hệ thống phải tuân thủ nghiêm ngặt các quy chuẩn dưới đây.

6.1 Cấu trúc Chuẩn hóa Dữ liệu Đầu ra (API Response Format)

Tất cả các API Endpoints trong hệ thống **bắt buộc** phải trả về định dạng JSON đồng nhất theo cấu trúc bọc (Wrapper Envelope), bất kể yêu cầu xử lý thành công hay thất bại.

A. Cấu trúc Response Thành công (Success Response)

Khi phản hồi thành công (HTTP Status **200 OK**, **201 Created**, v.v.), cấu trúc JSON trả về như sau:

```
{
  "success": true,
  "status_code": 200,
  "message": "Mô tả ngắn gọn kết quả thực hiện thành công",
  "data": { ... } | [ ... ] | null,
  "timestamp": "2026-08-02T18:15:30Z"
}
```

- **success** (Boolean): true biểu thị phản hồi thành công.
- **status_code** (Integer): Mã trạng thái HTTP chuẩn tương ứng.

- **message** (*String*): Thông điệp thông báo kết quả cho người dùng/developer.
- **data** (*Object | Array | Null*): Chứa nội dung dữ liệu chi tiết (DTO/Entity) hoặc danh sách đối tượng (đối với API Get List). Nếu không có dữ liệu trả về (ví dụ Delete), giá trị này là null.
- **timestamp** (*String*): Thời điểm phản hồi theo chuẩn ISO 8601 (UTC).

B. Cấu trúc Response Thất bại / Lỗi (Error Response)

Khi xảy ra lỗi do nghiệp vụ hoặc lỗi hệ thống (HTTP Status **4xx**, **5xx**), cấu trúc JSON trả về như sau:

```
{
  "success": false,
  "status_code": 400,
  "error_code": "INVALID_INPUT_DATA",
  "message": "Dữ liệu đầu vào không hợp lệ",
  "errors": [
    {
      "field": "email",
      "message": "Email không đúng định dạng"
    },
    {
      "field": "password",
      "message": "Mật khẩu phải có tối thiểu 6 ký tự"
    }
  ],
  "timestamp": "2026-08-02T18:15:30Z"
}
```

- **success** (*Boolean*): false biểu thị thất bại/có lỗi.
- **error_code** (*String*): Mã lỗi định danh dạng Constant (VD: UNAUTHORIZED, USER_NOT_FOUND, COURSE_ARCHIVED) giúp Frontend xử lý logic đa ngôn ngữ hoặc hiển thị UI tương ứng.
- **errors** (*Array | Null*): Danh sách chi tiết các trường bị lỗi validation (thường dùng cho lỗi 400 Bad Request). Nếu là lỗi hệ thống chung, trường này có thể là null

6.2 Quy trình Xử lý Ngoại lệ (Global Exception Handling)

Hệ thống phải triển khai bộ xử lý lỗi tập trung **@ControllerAdvice** /

@RestControllerAdvice trong Spring Boot để bắt (intercept) và đóng gói toàn bộ ngoại lệ sinh ra trong quá trình chạy ứng dụng.

A. Mã HTTP Status và Mã lỗi chuẩn (Error Code Mapping)

HTTP Status	Error Code Constant	Ngữ cảnh nguyên nhân gây lỗi
400 Bad Request	INVALID_INPUT_DATA	Dữ liệu gửi lên sai định dạng, thiếu các trường NOT NULL hoặc không qua được Validation.
400 Bad Request	DUPLICATE_RESOURCE	Vi phạm ràng buộc duy nhất (VD: Trùng Email, Username, hoặc Đăng ký trùng khóa học UNIQUE(student_id, course_id)).
401 Unauthorized	EXPIRED_JWT_TOKEN	Token JWT đã hết hạn sử dụng.
401 Unauthorized	INVALID_JWT_TOKEN	Token JWT không hợp lệ, bị chỉnh sửa hoặc sai chữ ký.
401 Unauthorized	BAD_CREDENTIALS	Sai thông tin đăng nhập (Username hoặc Password không đúng).

403 Forbidden	ACCESS_DENIED	Người dùng chưa được cấp quyền thực hiện chức năng (VD: Student cố xóa bài học, hoặc Admin cố chỉnh sửa Role của Admin khác).
404 Not Found	RESOURCE_NOT_FOUND	Không tìm thấy tài nguyên theo ID yêu cầu (VD: user_id, course_id, lesson_id không tồn tại).
409 Conflict	INVALID_STATE_TRANSITION	Thao tác sai quy trình trạng thái (VD: Thêm bài học vào khóa học đã đóng ARCHIVED).
500 Internal Server Error	INTERNAL_SERVER_ERROR	Lỗi ngoại lệ hệ thống không lường trước (Cần che giấu thông tin Stack Trace gốc để đảm bảo an toàn bảo mật).

B. Yêu cầu An toàn và Bảo mật khi Xử lý Ngoại lệ

- Che giấu chi tiết kĩ thuật (Information Hiding):** Tuyệt đối **không** trả về các đoạn thông tin nhạy cảm như Stack Trace, truy vấn SQL thô (DataAccessException), hay cấu trúc mã nguồn ra giao diện Client ở môi trường Production.
- Ghi vết Lỗi (Logging):** Mọi Exception nghiêm trọng (500 Internal Server Error) phải được hệ thống ghi log chi tiết (Sử dụng SLF4J / Logback) kèm thông tin timestamp, user_id và Stack Trace đầy đủ trên Server để phục vụ quá trình tra cứu (Debugging).
- Validation tự động:** Sử dụng các Annotation của Jakarta Bean Validation (như @NotNull, @NotBlank, @Size, @Email, @Min, @Max) trực tiếp tại các DTO Request để bắt lỗi ngay ở tầng Controller trước khi đi vào tầng Service.